

Cyber Threat Intelligence

Executive Briefing

Report Date: July 11, 2026

Generated: 2026-07-11 00:02 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
0	8	12	0	20

2. Executive Summary

As of July 11, 2026, the security operations center has completed a comprehensive analysis of 20 identified vulnerabilities, categorized as 0 Critical, 8 High, 12 Medium, and 0 Low. The current organizational risk posture is classified as moderate, characterized by high-complexity denial-of-service and server-side request forgery risks that threaten service availability and infrastructure integrity. The primary threat priority is CVE-2026-49866, involving CPU denial-of-service in Libp2p control messages, as it facilitates direct service disruption to critical network communication protocols. We mandate an immediate transition to an enhanced defensive posture, requiring prioritized patch deployment and tactical mitigation for all identified high-severity vectors within the next 48 hours.

3. Critical Action List

- Execute immediate emergency patching and resource throttling for CVE-2026-49866 across all Libp2p network nodes within 24 hours.
- Implement stringent outbound traffic filtering and SSRF protections for the Kimai invoice rendering module by close of business tomorrow.
- Deploy resource consumption limits and URL scheme validation for the Tesla Framework to mitigate CVE-2026-48597 atom exhaustion within 48 hours.
- Apply payload size verification and decompression limits for the Tesla Framework to address CVE-2026-48594 by July 13, 2026.
- Restrict input processing for the Mistune library to prevent quadratic parsing cycles for CVE-2026-49851 within 48 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
--------	--------------	------	----------	---------	-----

CVE-2026-49866	CPU DoS in Libp2p Control Messages	7.5	High	68/100	CWE-20
CVE-2026-49865	SSRF in Kimai PDF Invoice Renderi...	7.5	High	68/100	CWE-918
CVE-2026-48597	Atom Exhaustion in Tesla Framework	7.5	High	68/100	CWE-770
CVE-2026-48594	Decompression Bomb in Tesla Frame...	7.5	High	68/100	CWE-409
CVE-2026-49851	Quadratic Parsing DoS in Mistune	7.5	High	68/100	CWE-400
CVE-2026-49836	Arbitrary File Write in psd-tools	7.1	High	66/100	CWE-22
CVE-2026-48862	PUSH_PROMISE Stream Growth in Mint	7.5	High	63/100	CWE-770
CVE-2026-49754	CONTINUATION Flood DoS in Mint	7.5	High	63/100	CWE-770
CVE-2026-48595	Authorization Leak on Tesla Redir...	5.3	Medium	59/100	CWE-178
CVE-2026-55252	Open Redirect in OpenRun	6.1	Medium	55/100	CWE-601
CVE-2026-49858	Cross-User Attribute Leak in API ...	5.9	Medium	53/100	CWE-524
CVE-2026-49838	GoBGP Panic on Invalid AS_PATH	5.9	Medium	53/100	CWE-129
CVE-2026-49837	OOB Read in GoBGP Capability Pars...	5.9	Medium	53/100	CWE-125
CVE-2026-49834	Log Threshold Bypass in sigstore-...	5.9	Medium	53/100	CWE-345
CVE-2026-53956	Path Traversal in Rattler Cache	5.4	Medium	49/100	CWE-22
CVE-2026-5078	Log Forging in Morgan Middleware	5.3	Medium	48/100	CWE-117
CVE-2026-48598	Multipart Smuggling in Tesla Fram...	5.3	Medium	43/100	CWE-116
CVE-2026-48596	CRLF Injection in Tesla Content-T...	5.3	Medium	43/100	CWE-93
CVE-2026-49753	Content-Length Header Bypass in M...	5.3	Medium	43/100	CWE-444
CVE-2026-49977	Arbitrary Cookie Deletion in Tart...	4.3	Medium	34/100	CWE-285

5. Detailed Vulnerability Findings

CVE-2026-49866

Finding: CPU DoS in Libp2p Control Messages

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-20

Score Provenance: CNA Official

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The libp2p library contains a denial-of-service vulnerability within its control message handling for I HAVE and I WANT arrays. The root cause is an insufficient validation of message array sizes, allowing oversized packets to exhaust CPU resources during processing. This vulnerability permits an unauthenticated remote attacker to trigger resource

exhaustion, causing an application-level denial of service.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specifically crafted series of I HAVE and I WANT gossipsub messages to the libp2p node. The node attempts to parse these oversized arrays without implementing strict size limits or memory allocation bounds. The CPU enters an infinite or high-latency loop while attempting to iterate through the malicious structures. This results in the service becoming unresponsive to legitimate network traffic.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49866>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49866>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49866>

CVE-2026-49865

Finding: SSRF in Kimai PDF Invoice Rendering

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-918

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1046, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Kimai is vulnerable to Server-Side Request Forgery via the invoice PDF rendering component that processes Markdown image URLs. The flaw exists due to an lack of input validation or allow-listing of requested URLs before the server attempts to fetch the remote content. An unauthenticated attacker can exploit this to force the server to perform requests to internal resources, compromising network segmentation.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies the invoice generation endpoint in Kimai that supports Markdown image embedding. The attacker submits a PDF generation request with an image URL set to an internal service, such as a local metadata service at 169.254.169.254. The server-side rendering engine attempts to fetch the URL, retrieving sensitive information that the attacker can extract from the generated document. This results in unauthorized access to internal network metadata and services.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49865>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49865>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49865>

CVE-2026-48597

Finding: Atom Exhaustion in Tesla Framework

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-770

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Tesla is vulnerable to atom exhaustion via the processing of untrusted URL schemes, which may trigger excessive resource consumption during parsing. The root cause is a lack of limit on the number of entities processed, allowing an attacker to force the framework into a state of resource exhaustion. This can lead to a denial-of-service condition where the server stops responding to legitimate requests.

Proof of Concept (PoC):

An unauthenticated attacker sends a high volume of requests to the Tesla framework that triggers the parsing of deep or recursive URL-based atom structures. The internal parser attempts to allocate memory or compute resources for each nested atom without appropriate bounds enforcement. The server's available memory or CPU capacity is depleted by the recursive requests. This results in an application-level denial of service for all users.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-48597>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-48597>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-48597>

CVE-2026-48594

Finding: Decompression Bomb in Tesla Framework

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-409

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Tesla is susceptible to a decompression bomb attack where a maliciously small compressed response body results in massive memory allocation. The vulnerability occurs because the framework fails to enforce ratio-based limits on decompression, allowing malicious payloads to trigger excessive system resource use. An unauthenticated attacker can effectively crash the service through memory exhaustion.

Proof of Concept (PoC):

An unauthenticated attacker sends a request to a Tesla-powered service that triggers a response containing an highly compressed data object. The attacker crafts the compressed object so that its expansion creates a stream of data exceeding available system memory. The server's decompression process attempts to fulfill the memory request, leading to an immediate OOM (Out-of-Memory) crash. This results in the complete unavailability of the affected service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-48594>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-48594>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-48594>

CVE-2026-49851

Finding: Quadratic Parsing DoS in Mistune

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The Mistune library is vulnerable to a denial-of-service condition due to quadratic-time complexity in its `parse_link_text` function. The root cause is the inefficient handling of link text pattern matching when processing deeply nested or complex Markdown constructs. An attacker can supply a specially crafted input to trigger extreme CPU consumption, effectively stalling the parsing service.

Proof of Concept (PoC):

An unauthenticated attacker submits a large Markdown text input containing an intentionally complex chain of nested links and formatting patterns to the application's input processing field. The Mistune engine's ``parse_link_text`` function enters a quadratic processing loop while trying to resolve the syntax. The server resource utilization spikes to 100%, causing the application to hang or timeout. This results in a widespread service degradation or complete denial of service for all users.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49851>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49851>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49851>

CVE-2026-49836

Finding: Arbitrary File Write in psd-tools

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 66/100 | CWE: CWE-22

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1068, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:H

Attack Vector	Local
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	High

Description:

The psd-tools library is vulnerable to arbitrary file write via path traversal in the smart-object filename parsing. The technical root cause is the failure to sanitize file paths extracted from the PSD metadata, allowing relative path segments

to escape the intended write directory. A malicious PSD file can be used by an attacker to overwrite arbitrary files on the local filesystem.

Proof of Concept (PoC):

An unauthenticated attacker sends a malicious PSD file containing a smart-object with a name set to '.././.././etc/passwd' or similar system path to a target user. The victim opens the file using an application leveraging psd-tools for processing. The library attempts to save the smart-object data to the specified location, writing the attacker-controlled content to the target file path. This results in a full system compromise via file overwriting.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49836>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49836>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49836>

CVE-2026-48862

Finding: PUSH_PROMISE Stream Growth in Mint

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 63/100 | CWE: CWE-770

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The mint HTTP/2 implementation is vulnerable to a denial-of-service attack via unbounded stream map growth caused by PUSH_PROMISE frames that lack a follow-up HEADERS frame. The technical root cause is a failure to enforce timeouts or resource limits for streams created via PUSH_PROMISE. An attacker can flood the server with these frames to exhaust system memory.

Proof of Concept (PoC):

An unauthenticated remote attacker initiates an HTTP/2 connection to a Mint-powered server. The attacker sends a high volume of PUSH_PROMISE frames without sending any corresponding HEADERS frames. The server creates internal state for each pending stream, which remains open indefinitely. The server's memory is exhausted, resulting in a denial-of-service condition for all legitimate incoming requests.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-48862>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-48862>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-48862>

CVE-2026-49754

Finding: CONTINUATION Flood DoS in Mint

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 63/100 | CWE: CWE-770

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The mint library is vulnerable to a denial-of-service via unbounded CONTINUATION/HEADERS frame accumulation. The root cause is the failure to limit the number of continuation frames allowed per request, allowing an attacker to hold connections open and consume server resources. This leads to connection starvation and service downtime.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a large series of HTTP/2 CONTINUATION frames to a Mint-enabled web server without completing the request. The Mint library processes each frame and keeps the connection state active while waiting for more data. The server's available connection slots and CPU time are consumed, preventing new requests from being serviced. This results in a persistent denial-of-service condition.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49754>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49754>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49754>

CVE-2026-48595

Finding: Authorization Leak on Tesla Redirects

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-178

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1530

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The Tesla framework incorrectly handles Authorization headers during cross-origin redirects due to case-sensitive filtering. This vulnerability allows the sensitive credentials to be leaked to third-party endpoints if the redirect target's case differs from the filter expectation. An attacker can capture these headers, facilitating further unauthorized access to protected resources.

Proof of Concept (PoC):

An unauthenticated attacker orchestrates a cross-origin redirect by controlling the destination of an application request. The attacker sets the redirection domain to a controlled server and manipulates the casing of the header filter to allow the Authorization header to pass through. The browser or framework transmits the valid Authorization header to the attacker-controlled server upon redirection. This results in the theft of authentication tokens for the victim's session.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-48595>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-48595>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-48595>

CVE-2026-55252

Finding: Open Redirect in OpenRun

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 55/100 | CWE: CWE-601

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1204

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

OpenRun is vulnerable to an open redirect due to improper validation of redirect URLs involving absolute paths or host identifiers. The technical root cause is a failure in the URL parsing logic to distinguish between local resource paths and malicious external hosts. An attacker can exploit this to redirect users to unauthorized, potentially malicious websites, facilitating phishing attacks.

Proof of Concept (PoC):

An attacker creates a malicious URL that uses the //host pattern to point to an external site. The attacker sends this URL as a parameter to the OpenRun redirection endpoint. The application processes the URL without adequate validation of the host component. The user is redirected to the attacker-controlled site, potentially leading to credential harvesting or malware delivery.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-55252>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-55252>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-55252>

CVE-2026-49858

Finding: Cross-User Attribute Leak in API Platform

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-524

Score Provenance: CNA Official

MITRE ATT&CK: T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

API Platform Core suffers from a cross-user attribute leak in JSON:API and HAL normalizers due to a missing isCacheKeySafe gate. This failure to validate the cache context allows data cached by one user to be served to another user, leading to unauthorized information disclosure. This vulnerability requires a specific configuration where data is cached using an unsafe key, potentially exposing sensitive data to unauthorized parties.

Proof of Concept (PoC):

An attacker monitors the application to identify frequently requested items served by the API Platform normalizers. The attacker induces a cache population with sensitive attribute data using their own session. A second victim user then requests the same resource, at which point the server retrieves the attacker-poisoned cache entry. This results in the leakage of sensitive user-specific attributes to unauthorized third parties.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49858>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49858>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49858>

CVE-2026-49838**Finding: GoBGP Panic on Invalid AS_PATH**

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-129

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

GoBGP is vulnerable to a service crash during confederation validation when encountering an empty AS_PATH attribute. The technical root cause is an unhandled case or nil pointer dereference within the BGP attribute parsing logic. An unauthenticated attacker can exploit this via malicious BGP peer communication to cause the GoBGP daemon to terminate unexpectedly.

Proof of Concept (PoC):

An unauthenticated attacker establishes a BGP connection to a GoBGP daemon peer. The attacker sends a BGP UPDATE message that omits the AS_PATH attribute in a confederation-enabled session. The GoBGP parsing logic fails to validate the presence of the required path data and triggers a runtime panic during attribute verification. This results in the GoBGP service crashing and losing connectivity to all active BGP peers.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49838>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49838>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49838>

CVE-2026-49837**Finding: OOB Read in GoBGP Capability Parser**

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-125

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
---------------	----------------

Attack Complexity	High
-------------------	-------------

Privileges Required	None
Scope	Unchanged
Integrity Impact	None

User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

GoBGP is vulnerable to an out-of-bounds read in its BGP OPEN capability parser when reading values exceeding declared CapLen boundaries. This vulnerability occurs due to insufficient length checks, allowing an attacker to read adjacent memory in the heap. This may lead to information disclosure if sensitive memory content is returned in error messages or protocol exchanges.

Proof of Concept (PoC):

An unauthenticated attacker initiates a BGP connection to a GoBGP target. The attacker crafts a BGP OPEN message containing a capability field with a CapLen value that does not match the actual length of the payload, causing the parser to read past the end of the intended data. The GoBGP process inadvertently reads out-of-bounds heap memory and returns portions of it in subsequent communication. This results in the potential leak of sensitive internal memory contents to the remote attacker.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49837>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49837>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49837>

CVE-2026-49834

Finding: Log Threshold Bypass in sigstore-go

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-345

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1555

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

The sigstore-go library has a multi-log threshold bypass vulnerability when verifying log records. The failure to correctly validate consistency across all required logs allows a single compromised log server to satisfy the entire threshold verification process. This compromises the integrity of signed artifacts if an attacker compromises one of the involved logs.

Proof of Concept (PoC):

An attacker compromises a single log server that is part of a multi-log threshold verification scheme. The attacker submits a malicious artifact metadata payload to the compromised log. The sigstore-go verification client accepts the single compromised log's signature as sufficient proof of artifact legitimacy, bypassing the requirement for cross-log verification. This results in the successful deployment or execution of unauthorized, unverified software artifacts.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49834>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49834>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49834>

CVE-2026-53956

Finding: Path Traversal in Rattler Cache

CVSS v3.1 Score: 5.4 | Severity: Medium | Urgency Score: 49/100 | CWE: CWE-22

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

Rattler is vulnerable to path traversal within the package cache during the construction of file paths from build strings. The root cause is the failure to validate the conda package build string, which can contain path separators to escape the target directory. An attacker can provide a malicious package build string to write or read arbitrary files on the local filesystem.

Proof of Concept (PoC):

An unauthenticated attacker hosts a malicious package repository that provides a crafted build string. The victim pulls this package using the Rattler client. The client attempts to cache the package and resolves a path containing '../' segments from the build string. This results in the package contents being written outside the intended cache directory, allowing for arbitrary file modification on the victim's system.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53956>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53956>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53956>

CVE-2026-5078

Finding: Log Forging in Morgan Middleware

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 48/100 | CWE: CWE-117

Score Provenance: CNA Official

MITRE ATT&CK: T1505

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

The morgan logging middleware is vulnerable to log forging due to unneutralized control characters in the :remote-user logging token. This issue arises because the input is reflected directly into logs without sanitizing CR/LF characters, allowing for arbitrary log entry manipulation. An attacker can exploit this to inject malicious data into log files, potentially deceiving administrators or interfering with automated monitoring tools.

Proof of Concept (PoC):

An unauthenticated attacker sends a HTTP request with a specially crafted user-agent or header value that populates the :remote-user token with newline and carriage return characters. The morgan middleware processes this input and writes a new, fabricated log entry to the server-side log file. The server logs now contain malicious data that mimics system alerts or hides the attacker's actual activities. This results in the compromise of log integrity and audit traceability.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-5078>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-5078>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-5078>

CVE-2026-48598

Finding: Multipart Smuggling in Tesla Framework

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 43/100 | CWE: CWE-116

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	Low	Availability Impact	None

Description:

The Tesla framework is susceptible to multipart part smuggling due to improper sanitization of content-disposition values. The technical root cause is the failure to escape special characters within the header, enabling attackers to inject additional parts into the multipart message. This can be exploited by an unauthenticated attacker to bypass downstream filtering or confuse the parsing logic of receiving services.

Proof of Concept (PoC):

An unauthenticated attacker constructs a malicious HTTP request utilizing the Tesla framework's multipart parsing logic. The attacker includes a specially crafted content-disposition header that introduces unintended boundaries or field components. The framework interprets the input incorrectly, smuggling a hidden part into the message body. This results in successful bypass of security validations applied only to the initial legitimate part.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-48598>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-48598>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-48598>

CVE-2026-48596

Finding: CRLF Injection in Tesla Content-Type

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 43/100 | CWE: CWE-93

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1134

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

The Tesla framework contains a CRLF injection vulnerability within the request `Content-Type` header processing. This occurs because the `add\_content\_type\_param` function fails to sanitize user-supplied input before embedding it into the header string. An attacker can inject CRLF characters to terminate the current header and begin injecting malicious headers or request body content.

Proof of Concept (PoC):

An unauthenticated attacker sends an HTTP request where the `Content-Type` parameter includes encoded CRLF characters. The Tesla framework's `add\_content\_type\_param` function parses the input and inserts the characters into the header structure of the generated outbound request. This results in the ability to poison downstream caches or perform HTTP Request Smuggling against secondary systems.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-48596>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-48596>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-48596>

CVE-2026-49753**Finding: Content-Length Header Bypass in Mint**

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 43/100 | CWE: CWE-444

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1134

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

The mint library accepts a non-RFC compliant '+' sign prefix in the Content-Length header, leading to potential request smuggling. This vulnerability arises from lax parsing logic that ignores deviations from the specification, potentially creating a desynchronization between different middlebox security filters. An attacker can leverage this discrepancy to bypass security controls implemented on the edge.

Proof of Concept (PoC):

An unauthenticated attacker sends an HTTP request using a `Content-Length` header with a leading '+' sign (e.g., `+100`). The Mint server parses the value correctly and proceeds with request handling, while a front-end load balancer may reject it or treat it as zero-length. This discrepancy allows the attacker to inject malicious requests that are processed by the back-end application but ignored by the security filter. This results in successful HTTP request smuggling or bypass of WAF protections.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49753>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49753>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49753>

CVE-2026-49977

Finding: Arbitrary Cookie Deletion in Tarteaucitron

CVSS v3.1 Score: 4.3 | Severity: Medium | Urgency Score: 34/100 | CWE: CWE-285

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1565

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	None

Description:

The Tarteaucitron library fails to properly validate the data-cookie attribute within its cookie consent management functionality. This vulnerability stems from an insecure client-side implementation that allows external influence over internal cookie removal operations. An attacker can leverage this flaw to delete arbitrary cookies, potentially disrupting session state or security controls for authenticated users.

Proof of Concept (PoC):

An unauthenticated attacker crafts a malicious web link targeting a user's browser. The attacker directs the user to trigger a Tarteaucitron configuration that includes a crafted data-cookie attribute. The victim's browser executes the deletion logic while processing the malformed attribute provided by the attacker. This results in the removal of the targeted application cookies from the victim's local browser environment.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49977>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49977>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49977>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>